LABORATUVAR 5 · SEÇİLEN MAKİNE · ROBOTLU MIG/MAG KAYNAK HÜCRESİ

SBOM / CVE / Patch

Çıktı: Vulnerability Decision

Ad Soyad Büşra Erdem **Grup** **Tarih**

Kavram: SBOM = yazılım malzeme listesi · CVE = açığın kayıt no'su · CVSS = ciddiyet (0–10). Bir CVE sizi etkiler mi? Üç şart: bileşen **var**, sürüm **etkileniyor**, açık **ulaşılabilir**.
Makine: Hürmaksan Otomasyon – robotlu MIG/MAG kaynak hücresi (S7-1500 PLC, Pilz safety PLC, robot kontrolörü, dikiş kamerası + IPC, uzak servis bağlantısı).

Verilen zafiyet kaydı

Bileşen	Component X (PLC firmware kütüphanesi) — hücredeki S7-1500 PLC
Sürüm	2.4
CVE	CVE-XXXX-XXXX
Önem	Critical (CVSS 9.8)
Yama	Mevcut

Görev — karar akışı

1 **Bu CVE sizi gerçekten etkiliyor mu? (üç şartı kontrol edin)**

SBOM'a bakılır. **Var:** Component X, hücrenin S7-1500 PLC firmware'inde bulunuyor. **Sürüm:** Kurulu sürüm 2.4, etkilenen aralıkta. **Ulaşılabilir:** PLC kontrol bölgesinde ve uzak servis/MES bağlantısı oraya ulaşabiliyor. Üç şart da sağlandığı için **etkileniyoruz**.

2 **Üretimi hemen durdurur musunuz? Neden / neden değil?**

Hayır, hemen durdurmayız. Önce telafi edici önlem alınır: uzak servis bağlantısı kapatılır, PLC'ye giden conduit kısıtlanır. Emniyet fonksiyonu (ışık perdesi/kapı → Pilz safety PLC → robot STO) ayrı çalıştığı için insan korunur. Açık safety PLC'yi de etkiliyorsa üretim durdurulur.

3 **Yamayı doğrudan mı uygularsınız, önce test mi? Nerede test?**

Önce test. Aynı PLC modelli test düzeneğinde ya da üretici (Siemens / Hürmaksan) onaylı ortamda denenir; kaynak çevrimi, döner tabla ve robot haberleşmesi kontrol edilir. Mevcut firmware yedeklenir, yama planlı duruşta sahaya uygulanır.

4 **Bu yama bir safety validation etkiliyor mu? Nasıl anlarsınız?**

Yamanın değiştirdiği bileşen listesine (release notes) bakılır. Safety PLC firmware'ine, PROFIsafe haberleşmesine veya robotun güvenli bölge fonksiyonuna dokunuyorsa safety validation tekrarlanır: ışık perdesi, kapı kilidi, E-stop testleri ve durma süresi ölçümü. Yalnızca normal PLC'yi etkiliyorsa fonksiyon testi yeterlidir; karar değişiklik kaydına yazılır.

5 **Yama mümkün değilse compensating control (telafi edici önlem) ne olur?**

Uzak servis varsayılan kapalı; PLC'nin ilgili portu firewall'da kapatılır; PLC ayrı alt bölgeye alınır; ağ izleme (anomali tespiti) eklenir; USB portları kilitlenir. Yama tarihi ve kalan risk risk register'a yazılır.

Bu föyün çıktısı **Vulnerability Decision** → Evidence Pack **EP 09 · 10 · 11** başlığına oturur.

CRA Incident Simulation

Çıktı: Incident Workflow

Ad Soyad Büşra Erdem **Grup** **Tarih**

Senaryo: Saat 10:15. Servis hesabında yetkisiz erişim tespit edildi. PLC konfigürasyonu değişmiş olabilir. Kaynak hücresi hâlâ çalışıyor. Vardiya sorumlusu sizsiniz.

Kavram: Bir olayda en değerli iki şey **zaman** ve **kanıt**tır. CRA'nın 24s / 72s / 14 gün yükümlülükleri iyi bir müdahale akışının doğal kilometre taşlarıdır.

Görev — zaman çizgisini doldurun

1 **10:15 — ilk 15 dk: Kimi ararsınız? İlk üç eyleminiz?**

Ararım: OT/bakım sorumlusu, IT güvenlik, iş güvenliği uzmanı, Hürmaksan servis.
İlk üç eylem: (1) Hücreyi kontrollü durdur, operatörleri robot alanından çıkar, robotu güvenli konuma al. (2) Uzak servis bağlantısını fiziksel olarak kes (VPN/4G), servis hesabını kilitle. (3) Saati, HMI ekranlarını ve alarmları fotoğrafla; hiçbir şeyi resetleme.

2 **İlk 2 saat: Emniyet güvende mi? Neyi korursunuz (kanıt!)? Hangi hesap kapatılır?**

Emniyet: Işık perdesi, kapı kilidi ve E-stop fiziksel olarak test edilir; safety PLC konfigürasyon checksum'ı kayıtlı değerle karşılaştırılır.
Kanıt: PLC ve robot programının mevcut hâli değiştirilmeden yedeklenir; jump server oturum kayıtları, firewall ve HMI olay logları dışa alınır.
Hesap: Servis hesabı ve aynı parolayı kullanan tüm hesaplar kapatılır. Hücre, temiz yedek yüklenip safety testi yapılmadan çalıştırılmaz.

3 **24 saat — CRA erken uyarı: Hangi bilgi hazır olmalı?**

Tespit zamanı; etkilenen ürün (kaynak hücresi, PLC modeli ve firmware sürümü); aktif istismar şüphesi; alınan ilk önlemler; aynı hücreyi kullanan diğer müşterilerin risk altında olup olmadığı.

4 **72 saat — CRA bildirim: Kök neden, etki, önlem — kim ne yapıyor?**

Kök neden: ör. paylaşılan servis parolası çalındı. **Etki:** hangi konfigürasyon değişti, safety etkilendi mi. **Önlem:** kişisel hesap + MFA, varsayılan kapalı uzak erişim.
Kim: OT teknik analiz · IT log analizi · Safety sorumlusu emniyet doğrulaması · Yönetim bildirim ve müşteri iletişimi (A = Yönetim).

5 **14 gün — son rapor: Hangi loglar/kayıtlar korunmuş olmalı?**

Jump server oturum kayıtları, VPN ve firewall logları, PLC/robot programının olay anı ve temiz yedek kopyaları, safety PLC checksum kayıtları, HMI alarm geçmişi, değişiklik yönetimi kayıtları, safety test tutanakları.

En sık hata: "Resetleyip devam edelim" — o düğme kanıtı sonsuza dek siler. Önce emniyet, hemen sonra kanıt.

Bu föyün çıktısı **Incident Workflow** → Evidence Pack **EP 13 Incident Response** başlığına oturur.

LABORATUVAR 7 · SEÇİLEN MAKİNE · ROBOTLU MIG/MAG KAYNAK HÜCRESİ

AI Safety Challenge

Çıktı: AI Fail-Safe Decision

Ad Soyad Büşra Erdem **Grup** **Tarih**

> **Kavram — Prediction ≠ Safety:** Yapay zekâ bir karar üretir; güvenliği garanti eden mimari YZ'nin dışında tanımlanmalıdır. Araçlar: fail-safe · human override · monitoring · confidence threshold · fallback.

Dikiş kamerası → YZ modeli (IPC) → OK / RED → Kaynak parametresi → Robot

YZ yalnızca kalite kararı verir. Robot hareketi ve emniyet fonksiyonu (Pilz safety PLC) üzerinde yetkisi yoktur.

Görev — üç başarısızlıkta güvenli davranış

1. **Model yanlış sınıflandırdı: Kusurlu parçaya OK verdi. Sistem ne yapmalı? İkinci kontrol / insan onayı var mı?**

   Zayıf dikişli taşıyıcı parça müşteride kırılabilir. Kritik parçalarda her partiden örnekleme ile **ikinci kontrol** yapılır (insan gözü veya kesit/sızdırmazlık testi). YZ'nin önerdiği parametre düzeltmesi sabit güvenli sınırlarla (akım/voltaj min–max) kırpılır; sınır dışı öneri reddedilir.

2. **Girdi manipüle edildi: Kamera verisi bozuk/sahte. Nasıl fark edilir? Şüpheli girdide ne yapılır?**

   Fark etme: Görüntü kalite kontrolü (bulanıklık, parlaklık, sıçrantıyla kirlenmiş lens), referans plakayla periyodik kalibrasyon, kamera–IPC arasında bütünlük kontrolü, art arda aynı kare gelmesi. **Şüpheli girdide:** Parça otomatik RED/karantina, parametre değişikliği dondurulur, son onaylı parametre setine dönülür, operatöre alarm verilir.

3. **Confidence düştü: Model "emin değilim" diyor. Eşik ne olmalı? Altında: dur / insana sor / fallback?**

   Eşik **%90** (pilot verilerle ayarlanır). %90 altı → parça "insana sor" kutusuna ayrılır, operatör onaylar. Art arda 3 düşük sonuç veya %70 altı → yeni çevrim başlatılmaz, son onaylı reçeteye dönülür (fallback), bakım çağrılır. Safety PLC ayrı çalıştığı için robot hareket güvenliği etkilenmez.

Karar tablosu — AI Fail-Safe Decision

Başarısızlık	Tanımladığınız güvenli davranış (hangi kavramla?)
Model yanlış sınıflandırdı	Kritik parçada örneklemeli insan kontrolü; YZ parametre önerileri güvenli sınırlarla kırpılır — **human override + fail-safe**
Girdi manipüle edildi	Görüntü kalite ve bütünlük izleme; şüphelide karantina, son onaylı parametreye dönüş, alarm — **monitoring + fallback**
Confidence düştü	%90 altı insana sor; art arda düşük veya %70 altı → dur, son onaylı reçete, bakım — **confidence threshold + fallback**

Bu föyün çıktısı **AI Fail-Safe Decision** → Evidence Pack **EP 03 + EP 15** başlığına oturur.